

MVA UNIFIED AGENT

Remediation Guide

Remediation guidance with implementation commands and validation checks.

Report Type	Remediation
Tool Source	Tenable.sc
Reporting Date	July 2026
Document Type	Remediation Guide

Contents

1. Executive Overview	2
2. Remediation Method	2
3. Remediation Actions	2
3.1 Apache Tomcat AJP Request Injection and Potential RCE	2
3.2 SSL Certificate Cannot Be Trusted	3
3.3 Microsoft SQL Server Unsupported Version Detection	4
3.4 SMB Signing Not Required	5
4. Validation Requirements	5
5. Reference Appendix	5

1. Executive Overview

This guide gives remediation teams an execution-ready view of vulnerabilities, remediation steps, command examples, and validation checks. The command blocks are designed to be copied into a change plan after environment-specific review.

2. Remediation Method

Each remediation item includes affected asset context, references, implementation steps, command examples, and validation requirements. Commands must be reviewed and adapted to the target environment before execution.

3. Remediation Actions

3.1 Apache Tomcat AJP Request Injection and Potential RCE

Affected Asset	10.20.1.234 / web-prod-01 / TCP 8009
CVE	CVE-2020-1938
Reference Links Used	https://tomcat.apache.org/security-9.html https://nvd.nist.gov/vuln/detail/CVE-2020-1938

Reference Summary

Apache and NVD describe this as an AJP trust/configuration issue affecting Tomcat versions before 9.0.31, 8.5.51, and 7.0.100 when the AJP connector is accessible to untrusted users.

Steps to Remediate

- Confirm whether the affected host is running a vulnerable Tomcat release and whether AJP is listening on TCP 8009.
- If AJP is not required, disable the AJP connector in server.xml and restart Tomcat.
- If AJP is required, upgrade Tomcat to a fixed release and restrict AJP to a trusted interface or loopback address.
- Configure an AJP shared secret when AJP must remain enabled, and align the reverse proxy connector with the same secret.
- Confirm TCP 8009 is not reachable from untrusted networks after the change.

Commands

Identify Tomcat version and AJP listener

```
# Run on the Tomcat host
export CATALINA_BASE=${CATALINA_BASE:-/opt/tomcat}
export CATALINA_HOME=${CATALINA_HOME:-/opt/tomcat}
$CATALINA_HOME/bin/version.sh
sudo ss -lntp | grep ':8009' || true
sudo grep -R "protocol=\\"AJP\\" \"$CATALINA_BASE/conf\" \"$CATALINA_HOME/conf\" 2>/dev/null
```

Disable AJP when not required

```
# Back up the config, comment out the AJP Connector in server.xml, then restart
sudo cp "$CATALINA_BASE/conf/server.xml" "$CATALINA_BASE/conf/server.xml.bak.$(date +%F)"
sudo vi "$CATALINA_BASE/conf/server.xml"
sudo systemctl restart tomcat || sudo systemctl restart tomcat9
```

Secure AJP when it is required

```
<!-- Example server.xml connector - adjust secret and address for the environment -->
<Connector protocol="AJP/1.3"
    address="127.0.0.1"
    port="8009"
    secretRequired="true"
    secret="CHANGE_ME_TO_A_LONG_RANDOM_SECRET" />
```

Validation After Remediation

- Run a new authenticated vulnerability scan and confirm the CVE-2020-1938 finding is closed.
- Confirm TCP 8009 is reachable only from the approved reverse proxy or local host.
- Attach the changed server.xml and Tomcat version output to the change ticket.

3.2 SSL Certificate Cannot Be Trusted

Affected Asset	10.20.1.235 / vpn-gw-02 / TCP 443
CVE	Not provided
Reference Links Used	https://www.tenable.com/plugins/nessus/51192 https://docs.tenable.com/whitepapers/useful-plugins/Content/UsefulPlugins/Resolving51192.htm https://docs.openssl.org/3.0/man1/openssl-s_client/ https://docs.openssl.org/3.0/man1/openssl-verify/

Reference Summary

Tenable plugin 51192 indicates the server certificate chain cannot be trusted. Tenable notes common causes such as an unknown/self-signed issuer, missing intermediates, invalid dates, or a signature that cannot be verified.

Steps to Remediate

- Identify the service, hostname, port, certificate subject, issuer, expiry, and chain presented by the affected asset.
- If the certificate is self-signed or issued by an internal CA, either replace it with an approved publicly trusted certificate or add the internal CA to the scanner trust configuration where appropriate.
- If the certificate chain is incomplete, install the required intermediate certificates on the service.
- If the certificate is expired or has the wrong subject/SAN, request and deploy a corrected certificate from the approved CA.
- Rerun the scan after the certificate chain validates cleanly.

Commands**Collect certificate and chain from the service**

```
# Replace DNS and port with the affected service from the CSV
openssl s_client -connect vpn-gw-02:443 -servername vpn-gw-02 -showcerts </dev/null > vpn-gw-02_chain.txt
openssl x509 -in vpn-gw-02_chain.txt -noout -subject -issuer -dates -ext subjectAltName
```

Verify certificate chain with an approved CA bundle

```
# Use the approved enterprise/public CA bundle path for the target environment
openssl verify -CAfile approved-ca-bundle.pem vpn-gw-02_leaf.pem
```

Tenable scanner trust handling when an internal CA is valid

```
# Tenable VM/Nessus: upload PEM encoded internal CA as documented by Tenable.
# Tenable.sc: create custom_CA.inc and custom_feed_info.inc, then upload the custom plugin feed bundle.
```

Validation After Remediation

- Confirm OpenSSL chain verification returns OK using the approved CA bundle.
- Confirm the service presents the complete chain after restart or reload.
- Rerun Tenable and confirm plugin 51192 is no longer reported for the asset/port.

3.3 Microsoft SQL Server Unsupported Version Detection

Affected Asset	10.20.2.118 / sql-prod-03 / TCP 1433
CVE	Not provided
Reference Links Used	https://learn.microsoft.com/en-us/sql/sql-server/end-of-support/sql-server-end-of-support-overview https://learn.microsoft.com/en-us/troubleshoot/sql/releases/find-my-sql-version https://learn.microsoft.com/en-us/troubleshoot/sql/releases/download-and-install-latest-updates https://learn.microsoft.com/en-us/sql/database-engine/install-windows/upgrade-sql-server

Reference Summary

Microsoft states that SQL Server versions have a support lifecycle and that end of support means Microsoft no longer provides servicing and support. Microsoft recommends upgrade, migration, or ESU where eligible.

Steps to Remediate

- Confirm the SQL Server version, edition, product level, and build number.
- Compare the detected build with Microsoft lifecycle and latest-update guidance.
- Backup up all affected databases and verify the backup before upgrade or migration.
- Choose the remediation path: in-place upgrade, side-by-side migration, Azure SQL migration, or Extended Security Updates when eligible.
- Patch to a supported SQL Server build and rerun validation queries after upgrade.

Commands

Identify SQL Server version and edition

```
-- Run in SSMS or sqlcmd against the affected instance
SELECT @@VERSION;
SELECT
    SERVERPROPERTY('ProductVersion') AS ProductVersion,
    SERVERPROPERTY('ProductLevel') AS ProductLevel,
    SERVERPROPERTY('Edition') AS Edition;
```

Back up and verify before remediation

```
-- Replace DBName and path for the target environment
BACKUP DATABASE [DBName]
TO DISK = 'D:\Backup\DBName_pre_upgrade.bak'
WITH CHECKSUM, INIT;

RESTORE VERIFYONLY
FROM DISK = 'D:\Backup\DBName_pre_upgrade.bak'
WITH CHECKSUM;
```

Post-upgrade validation

```
SELECT @@VERSION;
SELECT name, state_desc, compatibility_level
FROM sys.databases
ORDER BY name;
```

Validation After Remediation

- Confirm the version/build maps to a supported Microsoft lifecycle state.

- Confirm application smoke tests and database jobs complete successfully.
- Rerun the vulnerability scan and confirm the unsupported SQL Server finding is closed.

3.4 SMB Signing Not Required

Affected Asset	10.40.8.21 / win-file-07 / TCP 445
CVE	Not provided
Reference Links Used	https://learn.microsoft.com/en-us/windows-server/storage/file-server/smb-signing https://learn.microsoft.com/en-us/windows-server/storage/file-server/smb-signing-overview https://learn.microsoft.com/en-us/powershell/module/smbshare/set-smbserverconfiguration

Reference Summary

Microsoft documents SMB signing as a control that verifies data integrity and helps prevent adversary-in-the-middle attacks. Microsoft provides PowerShell and Group Policy methods to require SMB signing.

Steps to Remediate

- Check whether SMB signing is required for both SMB client and SMB server configuration.
- Enable SMB server signing for inbound connections on file servers.
- Enable SMB client signing for outbound connections on endpoints and servers that initiate SMB sessions.
- For domain rollout, configure the matching Group Policy settings under Local Policies > Security Options.
- Validate configuration and monitor for legacy application or device compatibility issues.

Commands

Check current SMB signing status
<pre>Get-SmbClientConfiguration Format-List RequireSecuritySignature Get-SmbServerConfiguration Format-List RequireSecuritySignature</pre>
Require SMB signing with PowerShell
<pre># Run from an elevated PowerShell session Set-SmbClientConfiguration -RequireSecuritySignature \$true Set-SmbServerConfiguration -RequireSecuritySignature \$true</pre>
Validate after change
<pre>Get-SmbClientConfiguration Format-List RequireSecuritySignature Get-SmbServerConfiguration Format-List RequireSecuritySignature gpupdate /force</pre>

Validation After Remediation

- Confirm both RequireSecuritySignature values return True where policy requires signing.
- Confirm SMB access still works for approved clients.
- Rerun the vulnerability scan and confirm SMB signing is no longer reported as not required.

4. Validation Requirements

Every remediation action should be verified through configuration evidence, service/application health checks, and a follow-up authenticated scan. Closure should be based on the vulnerability no longer appearing for the same asset, port, protocol, and plugin or definition identifier.

5. Reference Appendix

Reference links are included to support remediation planning and validation.